Data Controller Evidence Checklist (EduPulse)

Effective Date: March 7, 2026

1) Purpose

This checklist summarizes evidence required for Data Controller registration and audits, aligned to Ghana Data Protection Act, 2012 (Act 843).

2) Governance and Accountability

- [ ] Appoint Data Protection Lead and backup owner.
- [ ] Maintain processing records (purpose, categories, legal basis, recipients, retention).
- [ ] Maintain current third-party processor list and signed agreements.
- [ ] Maintain breach response contacts and escalation paths.

Evidence:

- `compliance/INFORMATION_SECURITY_POLICY.md`
- `compliance/INCIDENT_RESPONSE_PLAN.md`
- `compliance/DATA_PROCESSING_AGREEMENT.md`

3) Data at Rest Controls

- [x] Field-level encryption for sensitive PII (parent/guardian contact fields, user email).
- [x] School bank details encrypted at application layer.
- [x] Passwords stored as one-way hashes.
- [ ] Database volume encryption and backup encryption documented and enabled in production.
- [ ] Key rotation procedure implemented and logged.

Evidence:

- `backend/security/crypto.py`
- `backend/api/models.py`

4) Data in Transit Controls

- [x] HTTPS/TLS deployment standard documented (TLS 1.2+).
- [x] HSTS and security headers configured at app/proxy layers.
- [x] Payment webhook signatures validated (HMAC).
- [x] CORS and origin protections configured.
- [ ] Confirm certificate renewal monitoring and alerting in operations runbook.

Evidence:

- `backend/api/api.py`
- `backend/routes.py`
- `PRODUCTION_DEPLOYMENT.md`

5) Access Control and Isolation

- ☑ JWT-based authentication in API.
- ☑ Role-based authorization for protected operations.
- ☑ Tenant isolation checks for school-scoped data access.
- ☑ Rate limits and login lockout policy in place.

Evidence:

- `backend/middleware.py`
- `backend/routes.py`
- `backend/settings.py`

6) Integrity and Auditability

- ☑ Audit logs for security/critical operations.
- ☑ Tamper-evident financial ledger chain integrity checks.
- ☐ Periodic audit-log review schedule and reviewer sign-off records.

Evidence:

- `backend/api/models.py`
- `backend/routes.py`

7) Data Subject Rights (DSAR)

- ☑ Privacy policy states rights (access, correction, deletion subject to law).
- ☑ Processor agreement includes controller support for data subject requests.
- ☐ DSAR intake workflow with response SLA and evidence retention operationalized.

Evidence:

- `compliance/PRIVACY_POLICY.md`
- `compliance/DATA_PROCESSING_AGREEMENT.md`
- `compliance/DATA_RETENTION_POLICY.md`

8) Immediate Pre-Submission Action List

1. Set strong production secrets for:
   - `JWT_SECRET_KEY`
   - `DATA_ENCRYPTION_KEY`
   - `LEDGER_SECRET_KEY`
2. Document and enable encrypted database backups.
3. Approve DSAR workflow SLA and assign owners.
4. Produce 90-day evidence pack:
   - Access review logs
   - Incident drills/tabletop record
   - Key rotation/change record
   - Backup restore test record

9) Sign-Off

- Data Protection Lead: _____ Date: _____
- CTO / Engineering Lead: _____ Date: _____
- School Proprietor (Controller Rep): ____ Date: _____